

— PGP TREINAMENTO · MATERIAL INSTITUCIONAL



CARTILHA · EDIÇÃO 2026

Cartilha *do PGP*

Programa de Governança em Privacidade

Guia de implementação da **LGPD** em instituições públicas brasileiras — para qualquer porte, sem pré-requisitos técnicos.

12 de junho de 2026

Lei nº 13.709/2018



O que você vai encontrar

A cartilha está organizada em três blocos: **a jornada do PGP** em 8 etapas, os **modelos institucionais** de documentos e os **capítulos de consulta** (glossário, FAQ, roteiros).

BLOCO 1



A jornada do PGP em 8 etapas

00	 Fase Preliminar — Sensibilização e Engajamento	p. 04
01	 Fase 1 — Formação das equipes de trabalho	p. 06
02	 Fase 2 — Diagnóstico Inicial	p. 08
03	 Fase 3 — Mapeamento e Análise de Riscos	p. 11
04	 Fase 4 — GAP Analysis	p. 15
05	 Fase 5 — Plano de Ação e Adequação	p. 18
06	 Fase 6 — Execução	p. 22
07	 Fase 7 — Monitoramento Contínuo e Melhoria	p. 28

BLOCO 2



Modelos institucionais

 **Política do PGP**

 **Comunicação ANPD**

 **Cláusulas LGPD em contratos**

 **Retenção e descarte**

 **Termo de consentimento**

 **Plano de Resposta a Incidentes**

BLOCO 3

Capítulos de consulta

 **Glossário LGPD essencial — 30 termos definidos** p. 32

 **Base legal — guia decisivo para o Setor Público** p. 37

 **Armadilhas comuns no setor público** p. 40

 **Adaptação por porte do órgão** p. 44

 **Calendário recomendado de revisões** p. 47

 **Checklist final do PGP — 25 perguntas** p. 49

 **Perguntas frequentes (FAQ)** p. 51

 **Referências externas curadas** p. 56

 **Roteiros de implementação — 30 / 90 / 365 dias** p. 58

 **Encerramento** p. 60



Apresentação

Esta Cartilha consolida, em formato pragmático e auto-suficiente, o caminho de implementação da **Lei nº 13.709/2018 — Lei Geral de Proteção de Dados Pessoais (LGPD)** — em Instituições Públicas brasileiras.

É material institucional para uso **independente**: não exige treinamento prévio, não depende de aplicativo, não requer conhecimento técnico avançado. O Encarregado e o Comitê de Privacidade do órgão podem usá-la como base de partida para estruturar o Programa de Governança em Privacidade (PGP) da Instituição.



O que esta cartilha NÃO é

- **Não é parecer jurídico institucional** — orienta, não vincula a Instituição perante a ANPD.
- **Não substitui consulta a especialistas** em casos de dúvida significativa.
- **Não é exhaustiva** — a LGPD tem 65 artigos + dezenas de Resoluções; aqui condensamos o essencial.
- **Não é receita única** — Instituições diferem em porte, contexto e cultura; adaptar é parte do trabalho.



Como usar



Leitura em sequência

Para quem está começando do zero. As 8 fases organizadas em sequência tornam o método completo.



Consulta pontual

Para dúvidas específicas. Use o sumário para ir direto ao instrumento que está estruturando.



Apoio à capacitação

FAQ, Glossário, Base Legal e Armadilhas servem de material didático em treinamentos internos.



Estrutura

- 8 etapas do PGP (Preliminar + Fases 1–7) com conteúdo institucional e modelos
- Modelos de documentos: Política do PGP · Comunicação ANPD · Cláusulas LGPD · Retenção · Consentimento
- Capítulos de consulta: Glossário (30 termos) · Base Legal (Art. 7º + Art. 11)
- Armadilhas comuns no setor público (10 situações reais)
- Adaptação por porte (pequeno · médio · grande)
- Calendário de revisões recomendado
- Checklist final do PGP (25 perguntas)
- FAQ — perguntas frequentes (19 respostas detalhadas)
- Referências externas curadas
- Roteiros de implementação por prazo (30 dias · 90 dias · 12 meses)

00

ETAPA ZERO • A DECISÃO INSTITUCIONAL



Fase Preliminar

Sensibilização e Engajamento

CONTEÚDO INSTITUCIONAL

A Fase Preliminar é o **degrau zero** do Programa de Governança em Privacidade. Antes de mapear processos, antes de designar Encarregado, antes de qualquer instrumento técnico, o órgão precisa ter a Alta Gestão *convencida* de que LGPD é prioridade institucional — não tarefa de TI nem capricho do Jurídico.

Sem esse patrocínio explícito do dirigente máximo, qualquer esforço posterior fica órfão: a Comissão não se reúne, o orçamento não sai, as áreas técnicas não cooperam, e o DPO vira figura decorativa. Por isso o trabalho começa **aqui**, antes mesmo da nomeação formal do Encarregado.



Como proceder

- 01** **Aplicar o Termômetro** — auto-diagnóstico em 2 blocos: quanto cada pessoa conhece a LGPD e em que etapa da jornada a Instituição está.
- 02** **Escrever a Carta para a Alta Gestão** — documento institucional curto com justificativa legal, riscos de não-cumprimento e pedido de apoio

concreto.

03 Apresentar um Roadmap inicial de 90 dias com marcos verificáveis — plano concreto, não promessas genéricas.

04 Obter comprometimento formal — idealmente um Ato/Despacho do dirigente máximo aprovando o início do PGP.

O QUE ESSA FASE ENTREGA

Não é documento técnico — é **decisão institucional**. Sai da Fase Preliminar com (a) consciência da equipe sobre o ponto de partida, (b) apoio formal da Alta Gestão por escrito, e (c) cronograma inicial acordado.

MODELOS DE REFERÊNCIA

Termômetro — auto-diagnóstico

Ferramenta em 2 blocos com scores separados: o primeiro mede o conhecimento de **cada pessoa**; o segundo mede em que etapa a **Instituição** está. Aplicar no início (linha de base) e repetir semestralmente.

PARTE 1 • SOBRE VOCÊ



Qual o seu contato com a LGPD até hoje?



No seu trabalho, você saberia dizer o que pode e o que não pode fazer com dados de pessoas?



Se acontecer um problema com dados pessoais, você sabe o que fazer?

PARTE 2 • SOBRE A SUA INSTITUIÇÃO



Os chefes (prefeito, secretários, diretores) compram a ideia de proteger dados?

↳ Fase Preliminar



Tem alguém responsável por proteção de dados no órgão?

↳ Fase 1



Vocês sabem quais dados de pessoas o órgão usa e onde ficam guardados?

↳ Fase 2



Vocês avaliam os riscos antes de usar dados delicados (saúde, crianças)?

↳ Fase 3



Vocês já compararam o que fazem hoje com o que a Lei exige?

↳ Fase 4



Existe um plano com prazos para resolver o que falta — e ele sai do papel?

↳ Fases 5 e 6



Depois de ajustar, vocês acompanham e revisam de tempos em tempos?

↳ Fase 7

Carta para a Alta Gestão — estrutura recomendada

1

Destinatário

Identificação formal do dirigente máximo (Prefeito(a), Presidente, Reitor(a)).

2

Justificativa legal

Síntese das obrigações decorrentes da LGPD — citação dos artigos relevantes (1º, 23–32, 41).

3 Riscos de não-cumprimento

Sanções administrativas, responsabilização civil, repercussão midiática, apontamentos do TC e MP.

4 Pedido concreto

Designação formal do Encarregado · Constituição do Comitê · Alocação de recursos · Agenda estratégica.

5 Assinatura

Responsável pela condução do trabalho.

COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Repetir o Termômetro Institucional a cada 6 meses para acompanhar a evolução real da maturidade.
- ✓ Apresentar a Carta da Alta Gestão em reunião de Comitê Gestor — não basta enviar por e-mail, é importante haver discussão e registro em ata.
- ✓ Construir um Plano de Comunicação Interna de LGPD: pílulas mensais por e-mail, banner na intranet, vídeo institucional curto.



Fase 1

Formação das equipes de trabalho

CONTEÚDO INSTITUCIONAL

A Fase 1 cumpre uma obrigação direta da LGPD: o **Art. 41** determina ao controlador a indicação de um Encarregado pelo Tratamento de Dados Pessoais (DPO). No setor público, essa indicação deve ser feita por **ato formal** — Portaria, Decreto ou Despacho — publicado no diário oficial e com canal de contato divulgado ao cidadão.

A **Resolução CD/ANPD nº 18/2024** detalha os critérios: perfil técnico-jurídico compatível, autonomia funcional, ausência de conflito de interesse e acesso direto à alta administração. A escolha não é livre — precisa de justificativa que demonstre aderência a esses critérios.



Como proceder

- 01** **Identificar candidato** com perfil técnico-jurídico compatível (não precisa ser advogado; precisa entender LGPD, segurança da informação e a realidade dos processos do órgão).
- 02** **Documentar a justificativa** da escolha (vai constar no Ato de Designação).

03 **Cadastrar contatos do Encarregado:** nome, e-mail institucional, telefone, endereço. Esses dados são públicos por força do Art. 41 §1º.

04 **Designar Encarregado Substituto** para continuidade em férias/afastamento (recomendação da ANPD).

05 **Emitir Ato de Designação formal** e publicá-lo no diário oficial.

06 **Divulgar os contatos do Encarregado** no Aviso de Privacidade público e na intranet do órgão.

✗ ERRO COMUM

Designar o Encarregado **verbalmente**, sem ato formal publicado, é incumprimento direto da LGPD. Em fiscalização ANPD, a primeira pergunta é "cadê o ato?". Se não tem, todas as defesas posteriores caem.

📌 MODELOS DE REFERÊNCIA

Ato de Designação — estrutura típica

CABEÇALHO

ATO DE DESIGNAÇÃO N° MM/AAAA

EMENTA

Designa o Encarregado em cumprimento ao Art. 41 da Lei n° 13.709/2018

CONSIDERANDOS

(a) Lei n° 13.709/2018 · (b) Resolução CD/ANPD n° 18/2024 · (c) necessidade de canal formal com ANPD e titulares

ART. 1º

Designa fulano(a) como Encarregado(a) — parágrafo único: contatos

ART. 2º

Justificativa da escolha – perfil técnico-jurídico, autonomia, acesso

ART. 3º

Atribuições conforme Art. 41 §2º da LGPD

ART. 4º

Vigência – entra em vigor na publicação

ASSINATURA

Autoridade máxima do órgão + ciência do designado(a)

Critérios da Resolução CD/ANPD nº 18/2024



Perfil técnico-jurídico

Não exige formação em Direito — exige domínio prático de LGPD.



Autonomia funcional

Proteção contra retaliação por decisões técnicas.



Sem conflito de interesse

Não deve ser auditado pela própria função.



Acesso direto à Alta Gestão

Sem intermediação burocrática.



Encarregado Substituto

Recomendado para continuidade em férias/afastamentos.



COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Publicar o Ato de Designação no Diário Oficial e arquivar a edição como prova documental.
- ✓ Constituir formalmente o Comitê de Privacidade por ato administrativo (TI, Jurídico, Comunicação, RH, áreas de negócio).
- ✓ Estabelecer calendário fixo de reuniões do Comitê (mensais no início, trimestrais quando consolidado).
- ✓ Divulgar os contatos do Encarregado em todos os canais externos: portal, redes sociais, materiais impressos, painéis físicos.

02

LEVANTAMENTO • ONDE OS DADOS MORAM



Fase 2

Diagnóstico Inicial

CONTEÚDO INSTITUCIONAL

A Fase 2 prepara o terreno para o mapeamento detalhado da Fase 3. **Não é Inventário ainda** — é o levantamento preliminar de onde a Instituição trata dados e quais processos entram primeiro na fila.

Em órgãos públicos, a tentação é tentar mapear TUDO de uma vez — o que afoga a equipe e atrasa entregas. A **Resolução CD/ANPD nº 2/2022** traz critérios objetivos para priorização: dados sensíveis, dados de crianças/adolescentes, larga escala, decisões automatizadas, alto impacto. A Fase 2 aplica esses critérios para definir quais 2–3 processos serão mapeados em detalhe primeiro.



Como proceder

- 01** **Levantar a lista bruta de setores** que tratam dados pessoais (Saúde, RH, Tributário, Ouvidoria, TI, Comunicação, etc.). Varredura inicial.
- 02** **Identificar 1–2 processos críticos** por setor (atendimento ao cidadão, folha de pagamento, prontuários, etc.).

03 **Aplicar a Matriz de Priorização** da Resolução nº 2/2022 — pontuar por dados sensíveis, volume, vulnerabilidade, etc.

04 **Selecionar os 2–3 processos mais críticos** para começar a Fase 3.

05 **Construir o Roadmap de 90 dias** detalhando como os processos prioritários serão mapeados.

06 **Acordar o cronograma** com a Alta Gestão e formalizar.

MODELOS DE REFERÊNCIA

Levantamento de setores — exemplo ilustrativo

Lista típica de setores que tratam dados pessoais em um órgão municipal.
Adaptar à estrutura específica da Instituição:



Recursos Humanos

Folha, contratação, seleções



Ouvidoria / Atendimento

Manifestações, denúncias



Tributário

Cadastro fiscal, IPTU/ISS



Saúde

Prontuários, agendamentos



Educação

Matrículas, responsáveis



Assistência Social

Cadastro de famílias



Tecnologia da Informação

Acessos, logs, sistemas



Comunicação

Mailing, redes, transmissões

Matriz de Priorização — Res. ANPD nº 2/2022

Critérios para priorizar quais processos entram primeiro no Inventário detalhado. Cada critério pontua em 3 níveis (1/2/3). Score final 0–18: **0–6 BAIXA**, **7–12 MÉDIA**, **13–18 ALTA** prioridade.



Volume de titulares

Quantas pessoas têm dados tratados por este processo?



Sensibilidade dos dados

Se enquadram no Art. 5º II (sensíveis)?



Vulnerabilidade dos titulares

Crianças, adolescentes, idosos, vulneráveis?



Exposição pública dos dados

São publicizados ou compartilhados amplamente?



Uso de tecnologias inovadoras

IA, decisões automatizadas, biometria?



Compartilhamentos com terceiros

Operadores ou outros controladores?

Roadmap de 90 dias — exemplo

Cronograma sugerido para os 90 dias seguintes ao início do trabalho — distribui as 7 Fases do PGP em 13 marcos semanais.

SEM.	FASE	ENTREGA
1	FASE 1	Encarregado(a) formalmente designado(a) e divulgado(a)
2	FASE 1	Comitê de Governança de Dados constituído e em operação

3	FASE 2	Lista priorizada de processos a serem mapeados
4	FASE 3	Inventário do Processo 1: Atendimento Posto de Saúde
5	FASE 3	Inventário do Processo 2: Sistema de Estagiários
6	FASE 3	Matriz de riscos aprovada + plano de mitigação inicial
7	FASE 4	GAP Analysis consolidado com score de conformidade
8	FASE 5	Plano de Ação institucional com cronograma
9	FASE 6	RIPD do processo mais crítico aprovado
10	FASE 6	Contratos com operadores em conformidade + canal DSR
11	FASE 6	Aviso de Privacidade publicado e divulgado
12	FASE 7	PRI institucional aprovado e testado
13	FASE 7	PGP em operação contínua

A Carta de Serviços como fonte de descoberta

Uma das maiores dificuldades é a pergunta: *"por onde começar o Inventário?"*. A resposta mais pragmática está num documento que TODO órgão público é obrigado a manter pela **Lei nº 13.460/2017**: a Carta de Serviços.

A Carta lista TODOS os serviços que o órgão presta — e cada serviço envolve, quase invariavelmente, tratamento de dados pessoais por trás. Usá-la como ponto de partida garante cobertura abrangente sem reinventar a roda.

MÉTODO PRÁTICO EM 5 PASSOS

1. **Localizar a Carta de Serviços vigente** — geralmente publicada no portal institucional ou na intranet.
2. **Listar todos os serviços oferecidos** — atendimento, ouvidoria, programas sociais, alvarás, tributos, saúde, educação, cultura. Pequeno: 20–40 serviços; médio: 80–150.
3. **Fazer 6 perguntas por serviço**: quais dados são coletados? de quem? finalidade? base legal? quanto tempo guardamos? com quem compartilhamos?
4. **Transformar serviços em processos do Inventário**. Serviços muito similares (vários alvarás com o mesmo fluxo) podem virar 1 processo único.
5. **Priorizar** aplicando a Matriz da Resolução nº 2/2022 (volume, sensibilidade, vulneráveis, exposição, tecnologias, compartilhamentos).

COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Atualizar a Matriz de Priorização semestralmente — processos mudam, novos sistemas entram, prioridades evoluem.
- ✓ Usar a Carta de Serviços como fonte de descoberta de processos: cada serviço vira potencialmente 1 processo.
- ✓ Acompanhar o cumprimento do Roadmap de 90 dias em reuniões mensais do Comitê de Privacidade.



INVENTÁRIO • ANÁLISE DE RISCOS



Fase 3

Mapeamento e Análise de Riscos

CONTEÚDO INSTITUCIONAL

Esta fase combina o **mapeamento detalhado** de todos os processos de tratamento de dados pessoais com a **análise dos riscos** associados a cada tratamento.



Parte 1 • Mapeamento

Documentar para cada processo:

- Quais dados são coletados
- Como (formulários, contratos, sistemas)
- Para que finalidade
- Qual a base legal
- Onde são armazenados
- Quem tem acesso
- Por quanto tempo
- Com quem são compartilhados
- Como são descartados



Parte 2 • Análise de Riscos

Para cada processo, avaliar:

- Riscos de vazamento
- Adequação das medidas existentes
- Vulnerabilidades técnicas
- Vulnerabilidades organizacionais
- Impacto potencial sobre titulares
- Riscos regulatórios
- Riscos reputacionais



Como proceder — 5 orientações

01 Comece pelos processos que mais expõem o cidadão

Processos com dados sensíveis, dados de crianças, ou grande volume. A vitória rápida vem desses.

02 A ordem dentro de cada processo importa

Não comece pela base legal — comece pelos **titulares**. Quem entrega o dado? Crianças? Pacientes? Idosos? Esse "quem" muda toda a análise.

titulares → dados coletados → finalidade → base legal → retenção → compartilhamentos → segurança

03 Riscos são concretos, não abstratos

Risco não é "pode haver vazamento". É "se o pendrive com 2.300 prontuários sair daqui, esses pacientes sofrem chantagem, estigma, ou perdem emprego". Conecte cada risco a uma consequência concreta.

04 Aprovação pelo DPO é parte do método

O DPO aprova ou devolve com motivo cada processo. Devolver não é punição — é parte do método.

05 Quem preenche o Inventário?

3 caminhos válidos: **(a)** DPO sozinho — para processos simples; **(b)** Contribuidor submete ao DPO — mais comum em órgãos públicos; **(c)** DPO + Contribuidor preenchem juntos — para processos com dados sensíveis ou risco alto.

MODELOS DE REFERÊNCIA

Inventário — 2 processos modelo



Atendimento ao Cidadão — Ouvidoria

SETOR	Ouvidoria
FINALIDADE	Receber, processar e responder manifestações de cidadãos sobre serviços públicos.
BASE LEGAL	Art. 7º II + Art. 7º III (obrigação legal — Lei nº 13.460/2017 + execução de políticas públicas)
TIPOS DE DADOS	Nome, CPF, e-mail, telefone, endereço, conteúdo da manifestação.
DADOS SENSÍVEIS	● Sim
RETENÇÃO	5 anos a partir do encerramento (prazo prescricional).
COMPARTILHAMENTO	Interno entre Ouvidoria e secretaria responsável; externo apenas mediante requisição legal (CGU, MP, Judiciário).
SEGURANÇA	Sistema com login individualizado, registro de acessos, criptografia em trânsito, backup criptografado.



Folha de Pagamento — Servidores

SETOR	RH
FINALIDADE	Processar mensalmente a folha de servidores ativos, inativos e pensionistas.
BASE LEGAL	Art. 7º II (Estatuto dos Servidores, CLT, legislação previdenciária e tributária)
TIPOS DE DADOS	Nome, CPF, RG, PIS, conta bancária, dependentes, descontos judiciais, dados de saúde (atestados).
DADOS SENSÍVEIS	● Sim
RETENÇÃO	75 anos para fins previdenciários; atestados médicos seguem 5 anos.
COMPARTILHAMENTO	Receita Federal, INSS, TC, sindicatos, instituição bancária pagadora.
SEGURANÇA	Sistema com login individualizado, segregação de função (cadastra ≠ aprova), logs auditáveis, backup criptografado.

Análise de Riscos — matriz $P \times I$



Vazamento por compartilhamento indevido

Categoria: Confidencialidade

Severidade: Probabilidade Média $\times$ Impacto Alto = **ALTO**

Descrição: Servidor da Ouvidoria encaminha por e-mail comum manifestação com relato de saúde do cidadão. E-mail interceptado ou compartilhado sem autorização.

Mitigação: Treinamento sobre dados sensíveis; substituição de e-mail por sistema corporativo com controle de acesso; checklist no fluxo de encaminhamento.



Acesso indevido à folha por servidor não autorizado

Categoria: Finalidade / necessidade

Severidade: Probabilidade Alta $\times$ Impacto Médio = **ALTO**

Descrição: Servidor com acesso amplo consulta dados de colegas por curiosidade, sem que seja necessário ao exercício de sua função.

Mitigação: Revisão dos perfis de acesso (menor privilégio); logs de consulta por CPF; auditoria periódica; treinamento + termo de responsabilidade individual.



COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Estender o Inventário gradualmente — meta razoável: 5 processos novos mapeados por trimestre.
- ✓ Submeter cada processo à aprovação formal do Encarregado antes de declarar como consolidado.
- ✓ Reavaliar a matriz de Risco anualmente — riscos mudam à medida que sistemas, terceiros e contextos mudam.

- ✓ Documentar mitigações implementadas e o efeito mensurável delas no nível de risco residual.

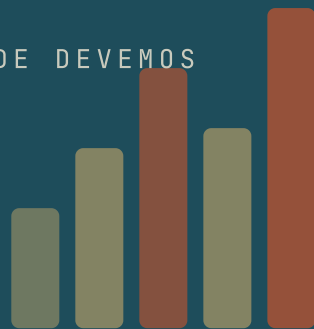


DIAGNÓSTICO · ONDE ESTAMOS VS. ONDE DEVEMOS
ESTAR



Fase 4

GAP Analysis



CONTEÚDO INSTITUCIONAL

Com base no mapeamento e análise de riscos da Fase 3, esta etapa identifica as **lacunas (gaps)** entre o estado atual e os requisitos estabelecidos pela LGPD e boas práticas.

O QUE É GAP ANALYSIS

Análise sistemática que compara o "**estado atual**" (**AS-IS**) com o "**estado desejado**" (**TO-BE**) de conformidade, identificando todas as lacunas a endereçar.

Áreas avaliadas



Bases Legais



Transparência



Direitos dos Titulares



Segurança



Contratos



Governança



Retenção



Treinamento



Como proceder — 5 orientações

01 ADERENTE significa praticado, não previsto

A pegadinha mais comum: marcar ADERENTE porque "existe uma política no papel". Não. Aderente é *"está sendo praticado de verdade, posso provar com um caso real dos últimos 12 meses"*.

Régua honesta: ADERENTE = praticado E documentado · PARCIAL = praticado mas inconsistente · NÃO ADERENTE = não praticado, mesmo no papel.

02 Pacote enxuto — 10 controles

Numa adequação real, o GAP completo tem 119 controles em 28 domínios. Para começar, 10 controles que cobrem 5 áreas (Governança, Bases Legais, Direitos, Segurança, Incidentes) já permitem aprender o método.

03 A justificativa importa mais que a classificação

"Não aderente — falta política de senhas formal; usuários compartilham logins administrativos" é insumo direto para o Plano de Ação. Capriche na justificativa.

04 Score baixo não é fracasso — é diagnóstico

Score 30% honesto vale 10x mais que 90% inflado. A ANPD não pune por baixa maturidade declarada — pune por descumprimento sem reconhecimento.

05 Apoio de outros setores é parte do método

Controles podem ficar marcados como "apoio pendente" com indicação do setor (Procuradoria, TI, RH). É honestidade institucional — nem todo controle o DPO consegue avaliar sozinho.

MODELOS DE REFERÊNCIA

Aplicação do GAP — 3 controles modelo

DPO / ENCARREGADO

✓ Aderente

Encarregado designado por ato formal e publicado

Encarregado designado por Portaria publicada no diário oficial. Contatos divulgados no Aviso de Privacidade público do portal institucional.

INVENTÁRIO

⦿ Parcial

Inventário atualizado nos últimos 12 meses

Inventário foi iniciado e cobre os 2 processos críticos identificados na Fase 2, mas ainda não foi estendido para a totalidade dos setores. Revisão programada para o próximo ciclo.

GESTÃO DE OPERADORES

✗ Não aderente

Contratos com cláusulas LGPD obrigatórias (Art. 39)

Levantamento dos contratos vigentes em curso. Maioria dos contratos com operadores foi celebrada antes da LGPD entrar em vigor — necessário promover aditamento com cláusulas mínimas.

COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Aprofundar a Análise de GAP estendendo dos 10 controles iniciais ao catálogo completo (Guia ANPD, Resolução nº 2/2022, ABNT 27701).

- ✓ Cada controle NÃO ADERENTE deve virar 1 ação no Plano com responsável e prazo.
- ✓ Repetir o GAP anualmente como instrumento de monitoramento da maturidade.



Fase 5

Plano de Ação e Adequação

CONTEÚDO INSTITUCIONAL

Com base nos riscos e lacunas das Fases 3 e 4, esta etapa cria um **plano de ação detalhado** para corrigir as não conformidades e implementar melhorias.

Elementos do Plano

- **Priorização** por criticidade
- **Responsáveis** nomeados
- **Prazos** realistas
- **Recursos** identificados
- **Indicadores** de sucesso

Ações típicas

- Políticas de Privacidade
- Adequação de contratos
- Medidas de segurança
- Treinamento de servidores
- Atendimento a direitos do titular
- Gestão de incidentes

Como proceder — 5 orientações

01 Plano é matéria-prima, não enfeite

Cada ação deve ter responsável **nomeado** (não "a área de TI"), prazo **concreto** (não "a definir") e indicador **mensurável** (não "melhorar a

segurança").

02 Importação do que já existe

Cada controle NÃO ADERENTE do GAP vira uma ação no Plano, e cada risco com plano de mitigação vira outra. Você não digita do zero — você edita o que veio da Fase 4.

03 Priorização honesta — 4 critérios

(a) risco ao titular se nada for feito · (b) prazo legal · (c) esforço de execução · (d) dependências entre ações. "Vontade política do gestor" não entra.

04 Acompanhamento mata o Plano de Gaveta

Reuniões CURTAS (15 min) quinzenais, projete o status no telão, cobre evidência (não "tá em andamento" — print, ata, link).

05 Conexão com a Fase 6 é direta

As ações viram conformidade quando executadas na Fase 6 (Políticas, RIPD, Terceiros, Aviso). O Plano é o contrato; a Fase 6 é a entrega.

MODELOS DE REFERÊNCIA

Plano de Ação — 3 ações modelo

AÇÃO	RESPONSÁVEL	PRAZO	ORIGEM
Aditivo contratual com cláusulas LGPD nos contratos pré-2020 ALTA	Procuradoria + Administrativo	04/09/26	GAP

Segregação de função no sistema de folha (perfil cadastrar ≠ aprovar)

TI + RH

07/08/26

RISCO

ALTA

Capacitação anual obrigatória em LGPD para servidores que tratam dados

RH + DPO

02/10/26

GAP

MÉDIA

COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Formalizar o PGP como Política institucional aprovada pelo dirigente máximo.
- ✓ Estabelecer ciclo de revisão anual do PGP com relatório formal ao gabinete.
- ✓ Vincular o orçamento do PGP ao planejamento estratégico (PPA/LDO/LOA).

Modelo — Política do Programa de Governança em Privacidade

Documento mater do PGP. Aprovado por ato formal do dirigente máximo. Cita os demais instrumentos (Inventário, Riscos, GAP, Plano, RIPDs, Operadores, DSR, Aviso, PRI) como anexos vinculados.

1. Objetivo

Estabelece o PGP de [NOME DA INSTITUIÇÃO], em cumprimento à LGPD, regulamentando o tratamento de dados pessoais no âmbito de suas atividades.

2. Abrangência

Aplica-se a todas as unidades, servidores, estagiários, terceirizados e demais agentes que realizem tratamento de dados pessoais.

3. Princípios

Observa os princípios do Art. 6º: finalidade, adequação, necessidade, livre acesso, qualidade, transparência, segurança, prevenção, não discriminação, responsabilização.

4. Governança

PGP é conduzido pelo Encarregado (Art. 41 LGPD), com apoio do Comitê de Privacidade — instância multidisciplinar (TI, Jurídico, Comunicação, RH, áreas de negócio).

5. Instrumentos

Integram o PGP, como anexos: (a) Inventário; (b) Análise de Riscos; (c) GAP; (d) Plano de Ação; (e) RIPDs; (f) Cadastro de Operadores; (g) Canal DSR; (h) Aviso de Privacidade; (i) PRI.

6. Responsabilidades

Dirigente máximo aprova e responde por sanções; Encarregado conduz operacionalmente; Comitê delibera; Gestores aplicam; Servidores cumprem; Operadores honram cláusulas.

7. Revisão e atualização

Revisada anualmente, ou antes em caso de: (a) alteração legislativa; (b) decisão ANPD; (c) incidente ALTA/CRÍTICA; (d) reorganização institucional relevante.

8. Vigência

Entra em vigor na data de sua publicação no diário oficial e revoga disposições em contrário.

06

OPERAÇÃO • O PAPEL SAI DA GAVETA



Fase 6

Execução

CONTEÚDO INSTITUCIONAL

A Fase 6 marca o momento de colocar em prática tudo que foi planejado. É onde a adequação à LGPD **sai do papel** e se torna realidade operacional.

Principais objetivos



Implementar Políticas e Documentação

Políticas externas e internas, POPs, contratos adequados e avisos



Executar Medidas de Segurança

Criptografia, controles de acesso, logs de auditoria, backups



Adequar Processos Operacionais

Coleta de dados, consentimentos, direitos dos titulares, incidentes



Treinamentos e Conscientização

Programa para todos os servidores (geral e específico por área)



Registrar Evidências de Compliance

Documentar implementações para o princípio de accountability



Como proceder — 6 orientações

01 A ORDEM importa: RIPD → Terceiros → DSR → Aviso

O Aviso de Privacidade é síntese pública — depende do RIPD, da lista de Terceiros e do canal DSR.

RIPD → 1-2 Operadores com cláusulas → Canal DSR → Aviso (12 seções ANPD)

02 Conteúdo NÃO se inventa — vem das fases anteriores

RIPD bebe do Inventário (Fase 3); Aviso bebe do RIPD; Políticas bebem do Plano (Fase 5).

03 Política externa vs. Política interna

Externa (site) é para o **cidadão** — linguagem simples, 12 seções ANPD. Interna é para **servidores** — responsabilidades do dia a dia, regras de acesso e descarte.

04 Terceiros que tratam dados: a maior dor invisível

Quase todo órgão tem dezenas de operadores. Cada um precisa de DPA com cláusulas específicas (Art. 39). Sem isso, em caso de incidente, a responsabilização pode vir 100% para a Instituição.

05 Direitos do Titular: 15 dias úteis é prazo curto

Quando um cidadão pede "me mostra todos os dados que vocês têm sobre mim" (Art. 18 II), você tem 15 dias úteis. Sem canal estruturado, o prazo estoura no primeiro pedido sério.

06 Sensibilização vs. capacitação

Sensibilização (1–2h) para TODO servidor. Capacitação (4–8h) para QUEM TRATA dados todo dia (RH, atendimento, TI). Públicos diferentes, treinamentos diferentes.

MODELOS DE REFERÊNCIA

RIPD — estrutura completa em 8 seções

Relatório de Impacto à Proteção de Dados (Art. 38 LGPD). Obrigatório para processos de alto risco. Exemplo: *Folha de Pagamento — Servidores*.

§ 01 Identificação do Controlador e do Encarregado

Controlador: a Instituição (qualificada no Aviso). Encarregado: nome do DPO, contatos públicos. Operadores envolvidos: sistema de folha contratado, instituição bancária pagadora.

§ 02 Descrição do tratamento e finalidades

Processamento mensal da folha de servidores ativos, inativos e pensionistas. Finalidade: cumprimento de obrigação legal.

§ 03 Necessidade e proporcionalidade

Dados estritamente necessários ao cálculo da remuneração e retenções. Dados de saúde só quando há afastamento e descartados ao final do prazo legal.

§ 04 Riscos identificados

(1) Acesso indevido por servidor sem necessidade. (2) Vazamento de informações sensíveis. (3) Erro de cadastro com impacto financeiro.

§ 05 Medidas de segurança e mitigação

Login individualizado, segregação de função, logs auditáveis com retenção mínima de 6 meses, backup criptografado, treinamento anual obrigatório.

§ 06 Mecanismos de exercício de direitos

Servidor pode solicitar acesso, correção, anonimização ou portabilidade pelo canal DSR. Prazo: 15 dias úteis (Art. 19 II).

§ 07 Decisão e responsabilidades

Tratamento necessário e proporcional. Medidas de mitigação reduzem riscos a nível aceitável. Aprovado pelo Encarregado em conjunto com Sec. de Administração.

§ 08 Revisão e atualização

Revisado a cada 12 meses ou antes, caso haja mudança significativa (novo sistema, novo operador, alteração legislativa).

Operadores — exemplo de cadastro



Empresa Hipotética de Tecnologia LTDA

CNPJ	00.000.000/0001-00
SERVIÇO	Hospedagem do sistema interno de ouvidoria (SaaS)
PAPEL	OPERADOR
CONTRATO N°	045/2024
CLÁUSULAS LGPD	☒ Sim
NÍVEL DE RISCO	MÉDIO

Canal DSR — exemplo de solicitação atendida

CONTATO	
DESCRIÇÃO	Solicitação de cópia das informações registradas, especialmente manifestações enviadas à Ouvidoria no último ano.
RESPOSTA	Encaminhada cópia do extrato com tarja em dados de terceiros. Prazo cumprido: 8 dias úteis.

 COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Todos os processos do Inventário com risco alto têm RIPD elaborado e aprovado.
- ✓ Aditamento contratual com cláusulas LGPD em todos os contratos com operadores.
- ✓ Divulgar o canal DSR em todos os pontos de contato com o cidadão.
- ✓ Manter o Aviso de Privacidade atualizado a cada mudança significativa.
- ✓ Documentar e treinar a equipe nas políticas de retenção e anonimização.

 Modelo — Cláusulas LGPD para contratos com operadores

Cláusulas mínimas obrigatórias (Art. 39 LGPD) para inclusão em contratos com terceiros. Para contratos vigentes pré-2020, promover aditamento.

CLÁUSULA 1 Objeto do tratamento

O OPERADOR realizará tratamento exclusivamente para os fins descritos no objeto, ficando vedado qualquer tratamento estranho a esse escopo.

CLÁUSULA 2 **Segurança e confidencialidade**

Medidas técnicas e administrativas adequadas (Arts. 46 a 49 LGPD).

CLÁUSULA 3 **Comunicação de incidentes**

Comunicação imediata, em prazo não superior a **24 horas**, fornecendo informações para subsidiar a comunicação à ANPD.

CLÁUSULA 4 **Subcontratação**

Sem prévia autorização escrita da CONTRATANTE. Sub-operador assume as mesmas obrigações por instrumento escrito.

CLÁUSULA 5 **Direitos dos titulares**

Auxílio em prazo não superior a **5 dias úteis** da requisição (Art. 18 LGPD).

CLÁUSULA 6 **Retenção, devolução e destruição**

Encerrada a relação, devolução ou destruição em prazo não superior a **30 dias**.

CLÁUSULA 7 **Auditoria**

Mediante aviso prévio de 15 dias úteis, diretamente ou por terceiro independente.

CLÁUSULA 8 **Responsabilidade**

Responde civilmente pelos danos do descumprimento (Art. 42 LGPD).



Modelo — Política de Retenção e Descarte

A LGPD exige (Art. 16) que os dados pessoais sejam eliminados após o término do tratamento, salvo hipóteses específicas. Esta política define prazos por categoria e procedimento de descarte seguro.

PRAZOS POR CATEGORIA — PARÂMETROS TÍPICOS DO SETOR PÚBLICO

Dados de servidores ativos	vínculo + até 75 anos
Servidores inativos / pensionistas	prazos previdenciários
Candidatos não selecionados	1 ano após validade do edital
Atendimento / Ouvidoria	5 anos após encerramento
Dados de saúde (prontuários)	20 anos da última consulta
Dados fiscais / tributários	geralmente 5 anos
Logs de acesso a sistemas	6 meses a 5 anos
Imagens de CFTV	30 a 90 dias
Licitantes não vencedores	5 anos após encerramento



Modelo — Termo de Consentimento do Titular

⚠️ ATENÇÃO

No Setor Público, consentimento é base legal **excepcional** — a regra é Art. 7º II (obrigação legal) ou Art. 7º III (execução de políticas públicas). Use consentimento APENAS quando o tratamento for facultativo (newsletter voluntária, autorização para uso de imagem). NÃO usar para atendimento obrigatório.

[NOME DA INSTITUIÇÃO], inscrita no CNPJ sob nº [XXX], com sede em [ENDEREÇO], na qualidade de Controlador (Art. 5º VI LGPD), solicita o consentimento de [NOME DO TITULAR] para o tratamento dos seguintes dados pessoais:

DADOS TRATADOS: [lista específica – ex: nome, e-mail, telefone, imagem]

FINALIDADE: [específica – ex: envio de informativo sobre eventos culturais]

PRAZO DE RETENÇÃO: [específico – ex: até descadastro pelo titular]

COMPARTILHAMENTOS: [se houver]

DIREITOS: o titular pode, a qualquer tempo, revogar este consentimento e exercer os direitos do Art. 18 da LGPD, pelo canal: [E-MAIL DO ENCARREGADO].

Declaro ter sido informado(a) sobre o tratamento dos meus dados e concordo livremente, de forma específica e inequívoca (Art. 5º XII).

Local, data: _____

Assinatura do(a) titular: _____

07

CONTINUIDADE • PGP É PROGRAMA, NÃO PROJETO



Fase 7

Monitoramento Contínuo e Melhoria

CONTEÚDO INSTITUCIONAL

A conformidade com a LGPD não é um projeto com início, meio e fim, mas um **processo contínuo**. Esta última fase estabelece os mecanismos de monitoramento, auditoria e melhoria contínua do programa de governança.

Atividades de monitoramento



Auditorias periódicas

Internas e/ou externas



Indicadores (KPIs)

Métricas de eficácia



Revisão de Políticas

Atualização periódica



Gestão de Incidentes

Acompanhamento e análise



Avaliação de Fornecedores

Verificação contínua



Atualização Legislativa

Mudanças na legislação



Como proceder — 6 orientações

01 Incidentes vão acontecer — a pergunta é se você está pronto

Pendrive perdido. E-mail para lista errada. Servidor demitido que levou backup. Não é possível prevenir 100%. A diferença entre o órgão que vira manchete e o que resolve em 72h é o **PREPARO**.

Res. CD/ANPD nº 15/2024: comunicação "em prazo razoável" → 3 dias úteis para incidentes ALTA. Sem PRI testado, é praticamente impossível cumprir.

02 Severidade objetiva (não gut feeling)

Res. 15/2024: BAIXA (sem acesso), MÉDIA (1 agravante), ALTA (2 agravantes), CRÍTICA (3+). Agravantes: dados sensíveis, vulneráveis, alto volume, dados financeiros. **Não chuta — calcula.**

03 Métricas que matam: 5 KPIs essenciais

 Tempo médio de resposta DSR vs. prazo legal de 15 dias úteis

 Nº de incidentes/trimestre vs. trimestre anterior

 % de servidores treinados em 12 meses

 Índice de conformidade em auditoria interna anual

 RIPDs realizados vs. processos críticos que exigem

04 Acompanhamento legislativo é parte do método

Crie um ritual: 1 hora/mês, DPO + 1 servidor abrem o site da ANPD, leem o que foi publicado, decidem o que vira ação. Custo: 12h/ano.

05 Auditoria interna anual é não-negociável

Não precisa ser auditoria externa cara — pode ser colega da Controladoria, com checklist baseado no GAP. Roda em 2–3 dias. Esse documento é a evidência viva de accountability.

06 PGP é programa contínuo, não projeto

A cada ciclo (anual), você revisa o que mudou, refaz o que precisa, melhora o que descobriu. É como manter um prédio — nunca acaba.

CICLO PDCA

Use o ciclo **Plan-Do-Check-Act** como metodologia para melhoria contínua. A adequação à LGPD é uma *jornada*, não um destino.

MODELOS DE REFERÊNCIA

Registro de incidente — exemplo

Acesso indevido a planilha de cadastro de servidores

ALTA

STATUS

Encerrado

COMUNICADO À ANPD

Sim — em até 3 dias úteis

COMUNICADO AOS TITULARES

Sim — em até 7 dias úteis

DESCRIÇÃO

Servidor com acesso amplo acessou planilha de cadastro contendo dados de 250 colegas (CPF, conta bancária, dados de dependentes) e fez cópia local sem autorização. Detectado por auditoria de logs ~5 dias depois.

MITIGAÇÃO

Revogação imediata do acesso · Apuração disciplinar instaurada · Notificação aos titulares · Revisão dos perfis de acesso.

Plano de Resposta a Incidentes (PRI)

Documento institucional que define a equipe responsável (ETIR) e a matriz de responsabilidades por etapa NIST. **Tem que estar pronto ANTES do incidente.**

Equipe ETIR — composição típica



DPO

PRIMÁRIO • contato 24h



TI

PRIMÁRIO • contato 24h



Jurídico

PRIMÁRIO • contato 24h



Comunicação

PRIMÁRIO • contato 24h



Alta Gestão

APROVADOR • contato 24h

Matriz RACI por etapa NIST

ETAPA	PAPEL	TIPO
Detectar	TI	R (responsável)
Detectar	DPO	I (informado)
Conter	TI	R (responsável)
Conter	DPO	A (aprovador)
Erradicar	TI	R (responsável)
Erradicar	Jurídico	C (consultado)
Recuperar	TI	R (responsável)
Recuperar	Dono do Processo	C (consultado)
Lições aprendidas	DPO	R (responsável)
Lições aprendidas	Alta Gestão	I (informado)



COMO APLICAR NA SUA INSTITUIÇÃO

- ✓ Realizar simulado de incidente pelo menos 1 vez ao ano — tabletop exercise com cenário plausível.
- ✓ Atualizar o PRI a cada mudança significativa de equipe, sistema ou perímetro.
- ✓ Estabelecer fluxo claro para comunicação à ANPD (formulário, lista de informações, aprovação interna).
- ✓ Manter histórico de incidentes registrados (mesmo os de baixa severidade) — vira insumo para a revisão anual.



Modelo — Comunicação de Incidente à ANPD

Conforme Art. 48 da LGPD e Resolução CD/ANPD nº 15/2024. Prazo: **até 3 dias úteis** após o conhecimento do incidente.

CAMPOS OBRIGATÓRIOS

- Identificação do controlador: nome, CNPJ, endereço, dados do Encarregado
- Data e horário em que o incidente ocorreu e em que foi detectado
- Descrição da natureza dos dados pessoais afetados
- Categorias e número aproximado de titulares afetados
- Indicação das medidas técnicas e de segurança utilizadas
- Riscos relacionados ao incidente
- Medidas adotadas para mitigar os efeitos
- Motivo do atraso, caso a comunicação não tenha sido imediata
- Identificação do responsável pela comunicação

A comunicação é feita pelo portal da ANPD (gov.br/anpd → **Comunicações à Autoridade**). Para incidentes ALTA/CRÍTICA, comunicar TAMBÉM aos titulares em até 7 dias úteis.



Glossário LGPD essencial

30 termos críticos organizados em ordem alfabética com definição compatível com a Lei. Use como referência rápida durante a leitura e nas reuniões do Comitê de Privacidade.

Anonimização

Art. 5º XI

Meios técnicos pelos quais um dado perde a possibilidade de associação a um indivíduo. Diferente de pseudonimização (que mantém a possibilidade de reidentificação).

ANPD

Art. 55-A

Autoridade Nacional de Proteção de Dados — órgão da Administração Pública federal responsável por zelar pela proteção de dados, fiscalizar a LGPD e aplicar sanções.

Aviso de Privacidade

Art. 9º

Documento público que informa ao titular como seus dados são tratados — finalidades, bases legais, retenção, compartilhamentos, canal de exercício de direitos.

Banco de dados

Art. 5º IV

Conjunto estruturado de dados pessoais, estabelecido em um ou mais locais, em suporte eletrônico ou físico.

Base legal

Art. 7º • 11

Fundamento jurídico que autoriza o tratamento. 10 hipóteses para dados comuns (Art. 7º); 8 mais restritivas para dados sensíveis (Art. 11). Toda atividade exige uma base documentada.

Comitê de Privacidade

Res.
18/2024

Instância multidisciplinar (TI, Jurídico, Comunicação, RH, áreas de negócio) que apoia o Encarregado nas decisões estratégicas do PGP.

Compartilhamento Art. 26

Uso compartilhado de dados por órgão público com outros órgãos. Permitido se houver finalidade específica, execução de políticas públicas e atribuições legais — sempre informado ao titular.

Consentimento Art. 5° XII · 8°

Manifestação LIVRE, INFORMADA e INEQUÍVOCA pela qual o titular concorda com o tratamento para finalidade determinada. Caixa pré-marcada NÃO é consentimento válido.

Controlador Art. 5° VI

Pessoa natural ou jurídica, de direito público ou privado, a quem competem as decisões sobre o tratamento. No setor público, é o próprio órgão (Prefeitura, Câmara, Tribunal).

Dado anonimizado Art. 5° III · 12

Dado relativo a titular que NÃO possa ser identificado, considerando os meios técnicos razoáveis. Sai do escopo da LGPD.

Dado pessoal Art. 5° I

Informação relacionada a pessoa natural identificada ou identificável. Inclui nome, CPF, e-mail, foto, geolocalização, IP — qualquer dado que identifique uma pessoa.

Dado pessoal sensível Art. 5° II

Dado sobre origem racial, convicção religiosa, opinião política, filiação a sindicato/organização religiosa, saúde, vida sexual, dado genético ou biométrico vinculado a pessoa natural.

Direitos do Titular (DSR) Art. 18 · 19 II

Direitos garantidos ao titular: confirmação, acesso, correção, anonimização/bloqueio/eliminação, portabilidade, informação sobre compartilhamento, revogação de consentimento. Atendimento em 15 dias úteis.

Encarregado (DPO) Art. 5° VIII · 41

Pessoa indicada pelo controlador para atuar como canal de comunicação entre o controlador, os titulares e a ANPD.

Finalidade Art. 6° I

Princípio do tratamento. Dados só podem ser tratados para propósitos legítimos, específicos, explícitos e

Incidente de segurança Art. 48 · Res. 15/2024

Evento adverso confirmado de violação na segurança de dados pessoais.

informados ao titular — sem possibilidade de tratamento posterior incompatível.

Comunicar à ANPD em até 3 dias úteis; aos titulares afetados em até 7 dias úteis.

Inventário de Tratamentos

Art. 37

Registro estruturado de TODOS os processos de tratamento — finalidade, base legal, tipos de dados, retenção, compartilhamentos, medidas de segurança por processo.

Necessidade

Art. 6º III

Princípio do tratamento. Limitação ao mínimo necessário para atingir a finalidade — dados pertinentes, proporcionais e não excessivos.

Operador

Art. 5º VII

Pessoa natural ou jurídica que realiza o tratamento em nome do controlador.
Ex: empresa contratada para hospedar prontuários, processadora da folha.

PRI

Art. 46 · 48

Plano de Resposta a Incidentes.
Documento institucional que define equipe responsável, fluxo de decisão, matriz RACI por etapa NIST e modelos de comunicação.

Privacy by Design / Default

Art. 46

Proteção de dados considerada DESDE A CONCEPÇÃO de qualquer novo sistema, processo ou serviço — e configurada por padrão.

PGP

Art. 50

Programa de Governança em Privacidade. Conjunto integrado de instrumentos (Inventário, Riscos, GAP, Plano, RIPDs, Operadores, DSR, Aviso, PRI) que organizam a conformidade.

RIPD

Art. 5º XVII · 38

Relatório de Impacto à Proteção de Dados. Descreve o tratamento que pode gerar riscos. Obrigatório para tratamentos de alto risco (sensíveis, larga escala, decisões automatizadas).

Sanção administrativa

Art. 52 · Res. 4/2023

Penalidades aplicadas pela ANPD: advertência, publicização, multa de até 2% do faturamento (R\$ 50 mi por infração), bloqueio/eliminação dos dados, suspensão das atividades.

Titular

Art. 5º V

Transferência internacional

Art. 33 · Res. 20/2024

Pessoa natural a quem se referem os dados pessoais objeto de tratamento.

Transferência de dados para país estrangeiro. Permitida em hipóteses específicas: adequação ANPD, garantias contratuais, normas corporativas, consentimento específico.

Transparência

Art. 6º VI

Princípio do tratamento. Garantia ao titular de informações claras, precisas e facilmente acessíveis sobre o tratamento e os agentes.

Tratamento

Art. 5º X

Toda operação com dados pessoais: coleta, produção, recepção, classificação, utilização, acesso, transmissão, armazenamento, eliminação, modificação, comunicação, transferência.

Tratamento por órgão público

Cap. IV
(23-32)

Realizado por pessoa jurídica de direito público em decorrência de competência legal ou execução de políticas públicas. Tem regime parcialmente próprio.

Vulneráveis (dados de)

Art. 14

Crianças, adolescentes, idosos e demais grupos em situação de vulnerabilidade. Tratamento exige cuidados específicos: dados de crianças só com consentimento de um dos pais.



Base legal

Guia decisivo para o Setor Público

Toda atividade de tratamento de dados precisa de uma base legal documentada. A LGPD oferece **10 hipóteses para dados comuns** (Art. 7º) e **8 hipóteses mais restritivas para dados sensíveis** (Art. 11). No setor público, nem todas são utilizáveis — algumas são típicas do setor privado.

Use o fluxograma abaixo. Quando há múltiplas opções aplicáveis, escolher a mais **específica e estável**: obrigação legal > política pública > legítimo interesse.



Fluxograma de decisão

1

O tratamento envolve dados SENSÍVEIS (saúde, opinião política, religião, biometria)?

→ **SIM**: Vai pro **Art. 11**. Bases comuns no setor público: Art. 11 II 'a' (obrigação legal), 'b' (políticas públicas), 'f' (tutela da saúde).

→ **NÃO**: Vai pro Art. 7º (próxima pergunta).

2

É OBRIGAÇÃO LEGAL específica (folha, contribuição previdenciária, livro fiscal)?

→ **SIM**: **Art. 7º II**. Base MAIS estável — citar a lei específica (Lei nº 8.112/90, Lei nº 8.666/93, etc.).

3 É EXECUÇÃO DE POLÍTICA PÚBLICA (UBS, programa social, fiscalização)?
→ **SIM:** Art. 7º III. Base TÍPICA do setor público para serviços ao cidadão.

4 É EXECUÇÃO DE CONTRATO ou procedimentos preliminares (licitação)?
→ **SIM:** Art. 7º V.

5 É indispensável para PROTEGER A VIDA (atendimento de urgência)?
→ **SIM:** Art. 7º IV. Excepcional — quando houver risco imediato.

6 É EXERCÍCIO DE DIREITOS em processo judicial, administrativo ou arbitral?
→ **SIM:** Art. 7º VI.

7 É necessário para LEGÍTIMOS INTERESSES?
→ **Art. 7º IX.** CUIDADO: no setor público é EXCEPCIONAL. Exige teste de balanceamento documentado (LIA). Não substitui base mais específica.

8 É FACULTATIVO do ponto de vista do cidadão?
→ **Art. 7º I** (consentimento). Base MAIS FRÁGIL — pode ser revogada a qualquer momento. Só para tratamentos genuinamente facultativos.

Erros comuns de classificação

✗ Usar consentimento para atendimento OBRIGATÓRIO

Cidadão não pode escolher — então não é consentimento. Base correta: Art. 7º III + Art. 11 II 'f' (saúde).

✗ Usar interesse legítimo sem teste de balanceamento

Exige documentação demonstrando que a finalidade do controlador supera os direitos do titular naquele contexto.

✗ Pular Art. 11 quando há dados sensíveis

Mesmo com base no Art. 7º, dados sensíveis exigem base ADICIONAL do Art. 11.

✗ Generalizar uma só base para todo o órgão

Cada processo do Inventário deve ter base ESPECÍFICA — não basta dizer "obrigação legal" sem citar a lei.

★ REGRA DE OURO

Começar sempre pelo **Art. 7º II** (obrigação legal específica) ou **Art. 7º III** (política pública). Essas duas bases cobrem 80–90% dos tratamentos típicos do setor público. Consentimento e legítimo interesse só para casos genuinamente facultativos ou excepcionais.



Armadilhas comuns no setor público

Determinadas práticas de tratamento aparecem com frequência nos órgãos públicos — algumas por inércia ("sempre foi assim"), outras por interpretação incorreta da Lei, outras por excesso de zelo na direção errada.

Use este capítulo durante a revisão do Inventário e do Aviso de Privacidade. Para cada processo / seção do Aviso, perguntar: *"caímos em alguma dessas?"*.

BLOCO 1 • ARMADILHAS EM PROCESSOS



Prefeitura — Posto de Saúde — empresa de marketing parceira

SITUAÇÃO TÍPICA

O posto envia "relatórios mensais com lista nominal e telefone dos pacientes hipertensos e diabéticos" para empresa de marketing parceira, que vende "campanhas de vacinação personalizadas via WhatsApp".

POR QUE É ARMADILHA

Compartilhar lista nominal + dados de saúde com fim comercial NÃO é finalidade de saúde pública. Falta base legal do Art. 11 e contraria o princípio da finalidade. Tratamento secundário com dados sensíveis exige consentimento específico ou hipótese explícita.

Base legal aplicável: Art. 6º I (finalidade) · Art. 11 (sensíveis) · Art. 39 (operador)



Prefeitura — Estagiários — newsletter com checkbox pré-marcado

SITUAÇÃO TÍPICA

O e-mail automático após inscrição também envia "newsletter da Prefeitura" sobre eventos culturais — a caixa "aceito receber comunicados" vem marcada por padrão.

POR QUE É ARMADILHA

Consentimento marcado por padrão (opt-out) NÃO é consentimento válido. Art. 5º XII exige manifestação "livre, informada, inequívoca e por ato afirmativo claro". Padrão deve ser opt-in. Finalidade "eventos culturais" também é distinta — exige consentimento separado.

Base legal: Art. 5º XII · Art. 8º · Art. 6º I



Câmara — Tribuna Livre — reels no Instagram sem aviso

SITUAÇÃO TÍPICA

Após a sessão, Comunicação publica reels no Instagram com "trechos das melhores falas" — nome do cidadão na legenda. Formulário de inscrição avisa sobre YouTube ao vivo, mas não menciona Instagram.

POR QUE É ARMADILHA

Base legal cobre a transmissão ao vivo — finalidade declarada. Reels editados no Instagram extrapolam: viram marketing institucional, com público diferente, expectativa diferente. Uso secundário sem informação prévia.

Base legal: Art. 6º I (finalidade) · Art. 6º IV (livre acesso) · Art. 9º (informação)



Câmara — Ouvidoria — newsletter para quem reclamou

SITUAÇÃO TÍPICA

A Ouvidoria envia trimestralmente "newsletter com os principais temas das manifestações" para TODOS os cidadãos que entraram em contato. Justificativa: "transparência ativa". Base: "interesse legítimo".

POR QUE É ARMADILHA

Interesse legítimo exige teste de balanceamento. Aqui NÃO passa — o titular procurou a Ouvidoria para resolver UMA questão específica, não para ser mailing recorrente. Expectativa razoável dele NÃO inclui isso. Transparência ativa cumpre-se publicando no portal, não no e-mail de quem reclamou.

Base legal: Art. 6º I, VI · Art. 10 (legítimo interesse) · Lei nº 12.527/2011 (LAI)

BLOCO 2 · ARMADILHAS NO AVISO DE PRIVACIDADE

Base legal incorreta — usa "consentimento" para atividade pública

§ 4

Serviço público (Posto de Saúde, Tribuna, Ouvidoria, Estagiários) NÃO usa consentimento. O correto é "execução de políticas públicas" (Art. 7º III) ou "obrigação legal" (Art. 7º II).

Art. 7º II, III · Art. 11 II 'a'

Dados sensíveis silenciados

§ 3

Quando o processo tem dados sensíveis (prontuário, denúncias), o Aviso deveria informar ao titular. Omitir viola transparência (Art. 6º VI) e dever de informação sobre sensíveis (Art. 11).

Art. 5º II · Art. 6º VI · Art. 11

Retenção vaga ("pelo tempo necessário")

§ 5

LGPD exige prazo CLARO e ESPECÍFICO (Art. 16). Texto genérico não cumpre transparência nem necessidade.

Art. 6º III, VI · Art. 16

Linguagem juridiquês ("outrossim", "consoante")

§ 6

Livre acesso e transparência exigem linguagem CLARA. "Outrossim", "consoante", "mister", "destarte" são juridiquês — afastam o cidadão. Pergunte: "sua mãe entenderia esta seção?"

Transferência internacional negada sem checar operadores

§ 8

Diz "não realizamos transferência internacional" sem verificar os operadores. Sistemas SaaS podem ter servidores fora do BR. Negar sem checar é informar errado.

Art. 33 · Art. 9º · Res. 20/2024

Canal DSR genérico em vez do canal real estruturado

§ 11

Usa contato genérico em vez do canal funcional estruturado. O canal precisa estar VIVO, acessível e divulgado. Prometer um canal que não existe é estelionato regulatório.

Art. 18 · §6º · Art. 19 II

LEMBRETE

Nenhuma destas armadilhas é "erro de gestor mal-intencionado" — todas são **erros humanos comuns**. Por isso a revisão estruturada importa: o erro escapa do olhar técnico individual, mas não escapa do checklist coletivo.



Adaptação por porte do órgão

A LGPD aplica-se igualmente a órgãos pequenos e grandes — mas o COMO implementar tem que se adaptar à realidade institucional.

Porte NÃO determina o que precisa cumprir, apenas COMO cumprir.



PORTE PEQUENO

Até 30 servidores

Câmaras municipais pequenas, autarquias compactas, conselhos profissionais regionais. Equipe enxuta, sem TI especializada.

ENCARREGADO

Servidor com acúmulo de função (jurídico + DPO, ou administração + DPO).

COMITÊ

3 membros · reuniões trimestrais

INVENTÁRIO



PORTE MÉDIO

30 a 200 servidores

Prefeituras de cidades médias, Câmaras maiores, autarquias regionais. TI estruturada, jurídico próprio.

ENCARREGADO

30–50% do tempo de um servidor. Pode ter Substituto formal.

COMITÊ

5–7 membros · reuniões mensais

INVENTÁRIO

20–50 processos. Saúde, Educação,



PORTE GRANDE

200+ servidores

Prefeituras de capitais, Câmaras Estaduais e Federal, Tribunais, Autarquias federais, agências reguladoras.

ENCARREGADO

Função DEDICADA (100%) + Substituto + equipe de apoio (2–5 servidores).

COMITÊ

10–15 membros · mensais + GTs temáticos

INVENTÁRIO

100+ processos. Ferramenta

5–10 processos críticos. Priorizar por risco.

GAP

Pacote enxuto (10–15 controles essenciais).

RIPDS

Só para processos genuinamente sensíveis.

TREINAMENTO

Capacitação anual coletiva (2–3h).

ORÇAMENTO

**~R\$ 5–15
mil/ano**

Tributário, RH, Assistência.

GAP

Pacote intermediário (30–50 controles).

RIPDS

~5–10 nos primeiros 12 meses.

TREINAMENTO

Trilha anual + onboarding + pílulas mensais.

ORÇAMENTO

**~R\$ 30–80
mil/ano**

dedicada.

GAP

Pacote completo (119+ controles).

RIPDS

Programa estruturado para todos os de alto risco.

TREINAMENTO

Plataforma EAD própria, certificação interna.

ORÇAMENTO

**R\$ 150
mil+/ano**

ATENÇÃO

Característica que pode SOBRESCREVER o porte: **tratamento de dados sensíveis em larga escala** (ex: Secretaria Estadual de Saúde tem porte "grande" independentemente do nº de servidores administrativos).



Calendário de revisões

Conformidade LGPD não é projeto com fim — é processo contínuo. Esta tabela orienta a periodicidade típica de revisão de cada instrumento do PGP. Adapte conforme o porte e os eventos disparadores específicos da sua Instituição.



Inventário de Tratamentos

Anual + contínuo

Processos novos, sistemas trocados, áreas reorganizadas. Cada novo sistema/processo deve entrar no Inventário ANTES do início do tratamento (privacy by design).



Análise de Riscos

Anual + após incidente

Riscos mudam com tecnologia, terceiros e contexto. Mudanças significativas nos processos disparam reavaliação dos riscos associados.



GAP Analysis

Anual

Conformidade é alvo móvel — novas resoluções ANPD, decisões judiciais. Cada "NÃO ADERENTE" deve gerar ação no Plano com responsável e prazo.



Plano de Ação

Mensal + revisão trimestral

Plano sem acompanhamento vira papel. Reuniões mensais do Comitê; trimestrais para repriorizar.



RIPDs

Anual + após mudança

Novo sistema, operador, alteração legislativa exigem reavaliação. RIPD desatualizado é problema em fiscalização.



Cláusulas LGPD em contratos

Anual + renovação

Contratos pré-2020 frequentemente não têm cláusulas LGPD. Promover aditamento progressivamente.



Canal DSR

Mensal + anual

Canal precisa estar VIVO — testar o e-mail/formulário todo mês. Indicador trimestral: % de solicitações respondidas em até 15 dias úteis.



Aviso de Privacidade público

A cada mudança + semestral

Aviso desatualizado em relação ao Inventário é informação incorreta ao titular. Incluir data da última atualização visível.



Plano de Resposta a Incidentes

Anual + após incidente

Equipe muda, tecnologia muda. Recomendado: simulado anual (tabletop). Sem simulado, plano é só papel.



Política do PGP

Anual

Aprovação anual pelo dirigente máximo cria ritual institucional. Anexar relatório executivo (1–2 páginas) com status de cada instrumento.



Capacitação da equipe

Anual + onboarding

Equipe muda, Lei muda. Onboarding obrigatório para novos servidores antes de tratar dados pessoais (Art. 50 § 2º I 'c').



Checklist final do PGP

25 perguntas de auto-avaliação organizadas pelas 8 etapas do PGP.
Repetir a cada 6 meses para acompanhar evolução.

-  **23–25** · PGP maduro  **18–22** · Consolidação  **12–17** · Em construção
-  **< 12** · Início

00 Fase Preliminar — Sensibilização

- ☐ A Alta Gestão (dirigente máximo) tem ciência formal do PGP e demonstra apoio institucional?
- ☐ A equipe envolvida no tratamento recebeu capacitação nos últimos 12 meses?
- ☐ Há documento que registra o ponto de partida da maturidade institucional (auto-diagnóstico, termômetro)?

01 Fase 1 — Governança

- ☐ O Encarregado (DPO) foi designado por ato formal e publicado no diário oficial?
- ☐ Os contatos do Encarregado estão divulgados no portal institucional (Art. 41 §1º)?

☐ Existe Encarregado Substituto designado para continuidade em férias/afastamentos?

☐ O Comitê de Privacidade foi instituído por ato formal com representantes das áreas-chave?

02 Fase 2 — Diagnóstico Inicial

☐ Foi feito levantamento preliminar dos setores que tratam dados pessoais no órgão?

☐ Foi aplicada a Matriz de Priorização (Res. ANPD nº 2/2022) aos processos identificados?

03 Fase 3 — Mapeamento e Riscos

☐ Existe Inventário de Tratamentos atualizado nos últimos 12 meses?

☐ Cada processo do Inventário tem base legal documentada e específica?

☐ Foi realizada Análise de Riscos com matriz Probabilidade × Impacto para os processos críticos?

04 Fase 4 — GAP Analysis

☐ Foi feita análise de conformidade (GAP) com pelo menos 10 controles essenciais?

☐ Cada controle NÃO ADERENTE virou ação no Plano com responsável e prazo?

05 Fase 5 — Plano de Ação

☐ Existe Plano de Ação consolidado com responsável e prazo por ação?

☐ Há acompanhamento periódico do Plano (mensal ou trimestral)?

06 Fase 6 — Execução

- ☐ Existem RIPDs elaborados para os processos de alto risco (dados sensíveis, larga escala)?
- ☐ Os contratos com operadores contêm cláusulas LGPD (Art. 39)?
- ☐ Existe canal para exercício de Direitos do Titular (DSR) divulgado e funcional?
- ☐ Há monitoramento do prazo de 15 dias úteis para resposta a solicitações DSR?
- ☐ O Aviso de Privacidade está publicado no portal externo, acessível ao cidadão (Art. 9º)?
- ☐ Existe Política de Retenção e descarte com prazos por categoria de dado (Art. 16)?

07 Fase 7 — Monitoramento e Resposta

- ☐ Existe Plano de Resposta a Incidentes (PRI) formalizado, com equipe definida e matriz RACI?
- ☐ O PRI foi testado nos últimos 12 meses (simulado)?

Perguntas frequentes

Compilação de perguntas que aparecem em treinamentos, atendimentos do canal DSR e reuniões do Comitê. As respostas têm caráter orientativo — não substituem parecer jurídico institucional.

01 Meu órgão é pequeno (menos de 50 servidores). Preciso mesmo de Encarregado?

SIM. A LGPD não dispensa o Encarregado em função do porte. O que muda é COMO designar: em órgão pequeno, pode ser servidor com acúmulo de função (jurídico + DPO), mas é obrigatório formalizar por ato.

02 O Encarregado pode ser servidor temporário ou comissionado?

Pode, com ressalvas. A Res. 18/2024 não veda, mas exige **autonomia funcional** — proteção contra retaliação. Servidor demissível ad nutum tem autonomia comprometida. Recomendação: preferir servidor de carreira.

03 Posso usar legítimo interesse (Art. 7º IX) no setor público?

PODE, mas é base EXCEPCIONAL. A regra é Art. 7º II (obrigação legal) ou Art. 7º III (política pública). Quando usar legítimo interesse, é obrigatório documentar o teste de balanceamento (LIA).

04 Por quanto tempo guardo o dado de cidadão atendido?

DEPENDE da categoria. Parâmetros típicos: atendimento geral = 5 anos; saúde (prontuários) = 20 anos; fiscais/tributários = 5 anos; previdenciários = até 75 anos. Após o prazo: eliminar, anonimizar ou justificar retenção em hipótese específica (Art. 16).

05 Tenho que pedir consentimento para tratar dado de servidor?

NÃO. Tratamento de dados de servidor (folha, ponto, prontuário funcional) decorre de OBRIGAÇÃO LEGAL (Art. 7º II).
Consentimento é base inadequada — servidor não pode RECUSAR sem prejuízo do vínculo. Usar consentimento APENAS para tratamentos facultativos.

06 Quando preciso elaborar RIPD?

Quando o tratamento pode gerar riscos às liberdades civis (Art. 38). Critérios:

- Trata dados SENSÍVEIS (saúde, opinião, etnia, biometria)
- Dados de CRIANÇAS/ADOLESCENTES sistematicamente
- LARGA ESCALA (milhares de titulares)
- Decisões AUTOMATIZADAS com efeitos jurídicos
- MONITORAMENTO sistemático (CFTV, geolocalização)
- TECNOLOGIAS INOVADORAS (IA, biometria)

07 O que fazer se ocorrer um incidente (vazamento)?

Fluxo em 7 passos:

1. **Detectar** e isolar o sistema afetado
2. **Acionar** o PRI (ETIR, DPO, TI, Jurídico, Alta Gestão)
3. **Classificar** a severidade
4. **Comunicar à ANPD** em até 3 dias úteis se ALTA/CRÍTICA
5. **Comunicar aos titulares** em até 7 dias úteis se ALTA/CRÍTICA
6. **Mitigar** — medidas técnicas e administrativas

08 Preciso publicar Aviso de Privacidade mesmo sendo órgão público?

SIM. A obrigação de informação ao titular (Art. 9º) aplica-se a TODOS os controladores. Recomendado: 1 Aviso institucional + Avisos específicos para serviços de maior impacto.

09 Carta de Serviços já não basta — por que preciso de Inventário também?

Funções diferentes. Carta = transparência sobre serviços. Inventário (Art. 37) = conformidade no tratamento. A Carta é fonte EXCELENTE para construir o Inventário, mas não substitui.

10 Posso compartilhar dados de cidadãos com outros órgãos públicos?

PODE, com regras. Art. 26 permite uso compartilhado quando há finalidade específica de execução de políticas públicas e atribuição legal, tratamento compatível e titular informado.

11 O que faço com os contratos antigos sem cláusulas LGPD?

ADITAMENTO. Promover aditivo contratual incluindo as cláusulas mínimas do Art. 39. Não é necessário rescindir — basta aditar. Priorizar contratos com valor significativo ou dados sensíveis nos primeiros 90 dias.

12 Posso enviar newsletter institucional para quem usou os serviços?

DEPENDÊ. Dentro da finalidade original = ok. Finalidade DIFERENTE (ex: newsletter cultural para quem fez denúncia) = exige **consentimento específico**. Caixa pré-marcada é inválida (Art. 8º). Opt-in real obrigatório.

13 A LGPD aplica-se a sessões públicas e transmissões?

Aplica-se com particularidades. Sessões têm base no princípio da publicidade (CF Art. 37). PORÉM: (a) participantes precisam ser INFORMADOS no formulário sobre transmissão e alcance; (b) uso secundário (reels editados) exige base própria; (c) dados sensíveis merecem cuidado redacional na divulgação.

14 Tenho que comunicar TODO incidente à ANPD?

NÃO. Art. 48 exige comunicação quando há risco/dano relevante. BAIXA = só registro interno. MÉDIA/ALTA/CRÍTICA = comunicar ANPD (e titulares se ALTA/CRÍTICA). Usar fatores objetivos para classificar.

15 Quanto custa implementar a LGPD?

Depende do porte. Pequeno (~30 servidores): R\$ 5–15 mil/ano. Médio (~100): R\$ 30–80 mil/ano. Grande (200+): R\$ 150 mil+/ano. CUSTO ZERO é miragem — mas custo BAIXO é viável em órgão pequeno com servidor capacitado.

16 Como diferenciar Inventário, RIPD, GAP e Plano de Ação?

Inventário descreve TUDO que é tratado. **GAP** avalia O QUE FALTA. **RIPD** avalia o RISCO RESIDUAL nos processos críticos. **Plano** organiza COMO CORRIGIR.

Inventário e GAP são panoramas; RIPD é zoom no crítico; Plano é execução.

17 A LGPD pode multar órgão público?

Sim, com adaptação. A ANPD pode aplicar: advertência, publicização, bloqueio/eliminação dos dados, suspensão das atividades. Multas pecuniárias (Art. 52 §1º) aplicam-se a entes privados — para entes públicos, a sanção tem efeito orçamentário-disciplinar.

18 Como capacitar a equipe sem orçamento dedicado?

5 caminhos com custo zero ou baixo:

1. Materiais GRATUITOS da ANPD
2. ENAP — cursos online gratuitos
3. Trilha LGPD Descomplicada — e-books gratuitos
4. Capacitação INTERNA — DPO capacita Comitê, Comitê capacita áreas
5. Pílulas semanais por e-mail

19 Quando devo revisar o PGP?

Anual completa + atualização contínua em eventos disparadores: novo sistema, alteração legislativa, decisão ANPD, incidente ALTA/CRÍTICA, reorganização institucional.



Referências externas curadas

Lista mínima e curada. Não busca exaustividade — busca **entregar aquilo que é efetivamente usado** no dia-a-dia. A ANPD publica regularmente novos materiais; consultar o portal periodicamente.



Legislação fundamental

Lei nº 13.709/2018 — LGPD

planalto.gov.br

Texto consolidado. Leitura obrigatória para Encarregado e Comitê.

Lei nº 12.527/2011 — LAI

planalto.gov.br

Lei de Acesso à Informação. Convive com a LGPD no setor público.

Lei nº 13.460/2017 — Defesa do Usuário

planalto.gov.br

Código de Defesa do Usuário do Serviço Público. Define direito à Carta de Serviços.

Marco Civil da Internet — Lei nº 12.965/2014

planalto.gov.br

Convive com a LGPD nas atividades de tratamento via Internet.



Resoluções da ANPD

Res. CD/ANPD nº 2/2022gov.br/anpd

Agentes de pequeno porte. Critérios de alto risco.

Res. CD/ANPD nº 4/2023gov.br/anpd

Regulamento de dosimetria e aplicação de sanções administrativas.

Res. CD/ANPD nº 15/2024gov.br/anpd

Comunicação de incidente de segurança com dados pessoais.

Res. CD/ANPD nº 18/2024gov.br/anpd

Atuação do Encarregado pelo Tratamento de Dados Pessoais.

Res. CD/ANPD nº 20/2024gov.br/anpd

Transferência internacional de dados pessoais.



Guias e materiais didáticos

Guia ANPD — Atuação do Encarregado

Detalhamento prático das atribuições do DPO, perfil recomendado, conflito de interesse.

Guia ANPD — Tratamento por órgãos públicos

Capítulo IV da LGPD aplicado às especificidades do setor público.

Guia ANPD — Segurança da Informação

Medidas técnicas e administrativas mínimas para proteção de dados pessoais.

Guia ANPD — Cookies e Proteção de Dados

Aplicação da LGPD a tecnologias de rastreamento em sítios eletrônicos.

Cartilha LGPD para agentes públicos (CGU)

Material da Controladoria-Geral da União com foco em servidores públicos.

ABNT NBR ISO/IEC 27701:2019

Sistema de Gestão de Privacidade da Informação. Padrão internacional.

Roteiros de implementação

A escolha do prazo depende do contexto: pressão externa acelera; orçamento e cultura institucional condicionam. Aqui 3 roteiros típicos — escolher o mais realista.

EMERGENCIAL

30 dias

Pressão externa imediata: notificação ANPD, fiscalização, incidente público. Foco em **entregas mínimas defensáveis** — não programa maduro.

- | | |
|---------------|---|
| SEM. 1 | Designar Encarregado + publicar contatos + iniciar Inventário (5 processos críticos) |
| SEM. 2 | Concluir 5 processos no Inventário + identificar 3 riscos altos + Plano inicial |
| SEM. 3 | Publicar Aviso de Privacidade básico + estabelecer canal DSR + comunicar incidentes anteriores se aplicável |
| SEM. 4 | Alta Gestão aprova Política do PGP (versão inicial) + cronograma dos próximos 90 dias |

Entregáveis: Ato de Designação publicado · Inventário de 5 processos · Aviso público · Canal DSR funcional · Política PGP v1 assinada.

90 dias

Sem pressão externa, mas com determinação institucional. É o prazo **mais recomendado** — equilibra qualidade e velocidade.

- | | |
|-------------------|---|
| SEM. 1-2 | Termômetro + Carta para Alta Gestão + designar Encarregado e Comitê |
| <hr/> | |
| SEM. 3-4 | Levantamento de setores + Matriz de Priorização + selecionar processos prioritários |
| <hr/> | |
| SEM. 5-7 | Inventário detalhado dos 10-15 processos prioritários |
| <hr/> | |
| SEM. 8-9 | Análise de Riscos + GAP Analysis (pacote 30 controles) |
| <hr/> | |
| SEM. 10-11 | Plano de Ação consolidado + iniciar RIPDs dos processos de alto risco |
| <hr/> | |
| SEM. 12 | Publicar Aviso · DSR · Operadores com cláusulas · esboçar PRI |
| <hr/> | |
| SEM. 13 | Alta Gestão: aprovação formal do PGP completo + próximos 90 dias |

Entregáveis: PGP completo · Inventário com 10-15 processos · RIPDs dos críticos · Aviso · DSR · Operadores · PRI inicial.

12 meses

Para órgãos que já têm PGP inicial e querem **amadurecer**. Foco em cobertura ampliada, capacitação contínua e ciclo de melhoria.

TRIM. 1

Estender Inventário para todos os setores (meta: 50%+ dos processos)

TRIM. 2

RIPDs para todos os de alto risco · GAP completo (119 controles) · adequação dos contratos antigos

TRIM. 3

Programa permanente de capacitação · simulado anual (tabletop) · revisão semestral do PGP

TRIM. 4

Cobertura total · indicadores institucionais · auditoria interna · relatório executivo

Entregáveis: PGP maduro com indicadores · Inventário com 80–100% de cobertura · Programa de capacitação contínuo · Auditoria interna anual · Política revisada.

 RECOMENDAÇÃO

Priorizar o **roteiro de 90 dias** como padrão. Emergencial só em pressão real (não é regra). Doze meses é continuidade, não início — começar SEMPRE com algum entregável visível em 30–90 dias para criar tração institucional.



FECHAMENTO

Boa jornada *na sua Instituição.*

Esta Cartilha condensa a experiência prática de implementação da LGPD em órgãos públicos brasileiros. **Não é o ponto final — é ponto de partida estruturado** para que cada Instituição construa o seu próprio Programa de Governança em Privacidade.

Três princípios para guardar



Patrocínio da Alta Gestão é condição prévia

Sem decisão estratégica explícita do dirigente máximo, qualquer esforço técnico vira papel.



O programa respira com a Instituição

Inventário, GAP, Plano e PRI são instrumentos vivos — exigem manutenção. Programa congelado envelhece em meses.



Cultura supera procedimento

Documentos bem feitos sem cultura institucional são apenas papel. A capacitação contínua e o exemplo das chefias importam mais que qualquer checklist.

Onde buscar ajuda

ANPD

Autoridade Nacional, primeira fonte oficial. Portal **gov.br/anpd** reúne Resoluções, Guias e canal de comunicações.

ENAP

Escola Nacional de Administração Pública, cursos gratuitos para servidores sobre LGPD.

Comunidade técnica

Grupos de DPOs do setor público trocam experiências em listas e fóruns. Privacy by Design não é solitário.

